

 Risk Control Management Document — Version 2.0

FAST-NUCES Islamabad — Accounting & Finance (AnF)

Department

Date: 2025

Prepared For: Information Assurance Project

Contents

1. Overview 3

2. Risk Treatment Methodology..... 3

3. Updated Risk Treatment Summary Table..... 3

4. Monitoring & Review Plan 7

5. Residual Risk Acceptance 8

6. Document Control..... 8

1. Overview

This updated Risk Control Management Document outlines corrective and preventive actions for **all Critical and High risks** identified in the updated Risk Assessment (Version 2.0).

Controls are linked to ISO 27001 Annex A, assigned to responsible personnel, and classified by implementation timelines.

2. Risk Treatment Methodology

FAST-NUCES A&F Department applies the following treatment strategies:

- **Mitigate:** Reduce impact/likelihood using controls
- **Avoid:** Stop activities causing unacceptable risks
- **Transfer:** Shift risk via vendor SLAs or insurance
- **Accept:** Accept low-level risks with documented approval

All Critical and High risks MUST be mitigated.

3. Updated Risk Treatment Summary Table

(Includes ALL Critical + High risks, including new ones)

 UPDATED RISK CONTROL MANAGEMENT TABLE (Version 2.0)

Ready for Word or Excel — fully aligned & clean

Risk ID	Risk Description	Risk Level	Treatment Plan	Responsible Person	Timeline	Annex A Controls	Success Indicators
RA-01	Weak passwords & no MFA allow ERP unauthorized access	Critical	Implement MFA; enforce password policy; apply RBAC	IT Dept + Head of A&F	0–1 month	A.5.17, A.8.2, A.9.4	MFA enabled; failed logins reduced
RA-03	Staff targeted by phishing attacks	Critical	Conduct cybersecurity training; improve spam filtering	IT Dept	0–1 month	A.6.3, A.8.12	100% training completion; phishing clicks reduced
RA-04	Outdated OS patches enable ransomware infection	Critical	Centralized patch management; remove admin rights	IT Dept	0–1 month	A.8.7, A.5.23	All systems patched; least-privilege enforced
RA-16	USB ports allow data exfiltration	Critical	Block USB ports; allow only whitelisted devices; apply DLP	IT Dept	0–1 month	A.8.10	Unauthorized USB usage blocked
RA-20	No MFA for staff email → account compromise	Critical	Enforce MFA on all Outlook accounts	IT Dept	0–1 month	A.9.4	100% MFA compliance

Risk ID	Risk Description	Risk Level	Treatment Plan	Responsible Person	Timeline	Annex A Controls	Success Indicators
RA-21	Exam papers may leak due to weak physical handling	Critical	Secure exam cabinets; restrict access; digitize papers	Faculty + Admin	0–1 month	A.7.4, A.8.28	Exam storage logs maintained; zero leakage
RA-22	Students misuse lab PCs	Critical	Implement restricted student accounts; monitoring; logging	Lab Engineer + IT	0–2 months	A.5.18, A.8.16	Logs show compliance; unauthorized actions blocked
RA-02	Payroll files unencrypted → data leakage	High	Encrypt payroll folder; enforce access control; enable DLP	Head of A&F + IT	1–2 months	A.8.24, A.8.28	Payroll directory encrypted & restricted
RA-05	Backups untested → risk of data loss	High	Perform quarterly restore tests; maintain logs	IT Dept	1–2 months	A.5.30, A.8.13	Successful restore test reports
RA-06	Cloud ERP outages disrupt finance operations	High	Create offline workflow; prepare manual receipt process	Head of A&F	1–2 months	A.5.29	Offline SOP ready & tested
RA-07	Weak vendor verification enables payment fraud	High	Introduce 2-step vendor verification; segregation of duties	Procurement + A&F	1–2 months	A.5.20, A.8.9	Verified vendor logs; no unverified payments

Risk ID	Risk Description	Risk Level	Treatment Plan	Responsible Person	Timeline	Annex A Controls	Success Indicators
RA-09	Laptops without encryption expose data if stolen	High	Enable BitLocker; mandate encryption for all laptops	IT Dept	1–2 months	A.8.11	Encryption status: 100% “enabled”
RA-11	Weak Wi-Fi password → unauthorized access	High	Implement WPA3; rotate password every 6 months; MAC filtering	IT Dept	1–3 months	A.8.20	Only approved MAC addresses connect
RA-13	ERP brute-force due to no lockout threshold	High	Enable lockout after 5 failed attempts	ERP Admin	0–1 month	A.8.23	Automatic lockouts enabled
RA-15	OneDrive misconfiguration exposes files publicly	High	Disable public sharing; enforce internal-only links	IT Dept	0–1 month	A.8.11	Sharing logs show internal-only usage
RA-18	Fake vendor calls trick staff (social engineering)	High	Create vendor verification SOP; mandatory callback	Procurement Dept	1–2 months	A.6.3	Verification logs maintained
RA-23	Logs not reviewed → undetected incidents	High	Monthly log reviews; assign log reviewer	IT Dept	1–2 months	A.8.14	Monthly log audit reports

Risk ID	Risk Description	Risk Level	Treatment Plan	Responsible Person	Timeline	Annex A Controls	Success Indicators
RA-24	Unlicensed/unauthorized software in labs	High	Perform software audit; enforce licensing; block unauthorized installs	Lab Engineer + IT	1-3 months	A.5.10, A.8.9	All systems show compliant software list

4. Monitoring & Review Plan

Activity	Frequency	Owner	Evidence
Log reviews (ERP, email, systems)	Monthly	IT Dept	Log audit reports
Backups restore test	Quarterly	IT Dept	Restore test results
Phishing simulations	Quarterly	IT Dept	User performance reports
Vendor verification checks	Monthly	Procurement	Verification records
MFA compliance review	Monthly	IT + Admin	MFA dashboard
Access review for sensitive data	Every 6 months	Head of A&F	Access review sheet

5. Residual Risk Acceptance

After implementation, some risks may remain minimally.
They will be accepted formally by:

- **Head of Accounting & Finance**
- **Campus IT Security Lead**
- **Internal Audit Department**

A signed acceptance form will accompany this document.

6. Document Control

Version	Date	Description	Prepared By	Approved By
2.0	2025	Updated based on revised Risk Assessment & PDF departmental data	Ahmed	Head of A&F